

COMPUTER SECURITY · FINAL UPDATE · PROJECT FORUM

Phishing Email Detection Using Large Language Models

A leakage-aware, cross-corpus and cost-aware benchmark of small open LLMs

Jahid Ibna Sinha (011221376)

Md. Jakaria Alam Saimon (011221002)

Nowshin Anjum Faria (011221372)

United International University
Group 18

From a suspicion to a measured result

15 JUL**Literature review**

5 papers, all 97 to 99%. Every one tests inside one dataset.

21 JUL**Preliminary run**

Train on one corpus, test on another: F1 0.99 fell to 0.30.

5 SEP**Proposal**

Six objectives and one empty table.

21 SEP**Final study**

169,921 emails checked for overlap, 40,498 model calls, \$1.58.

What we corrected after review

We are not first

Two 2025-26 papers already test across corpora. Ours is what they skip: removing the overlap, cost, and false alarms.

We added a control

Decontamination also shrinks the training set, so we remove the same number of emails at random to prove the cause.

We verify exactly

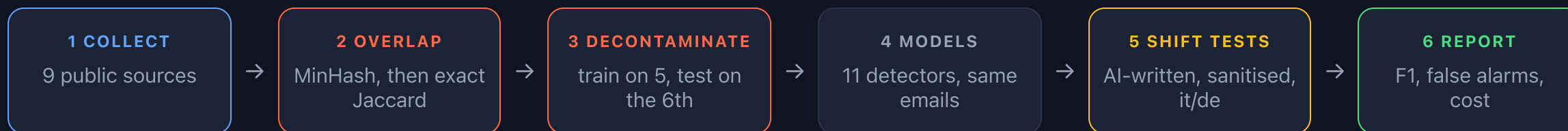
Every duplicate pair is confirmed with exact similarity, and the matcher is checked against brute force.

Question: if we remove leaked emails and always test on a corpus the model has never seen, how good are cheap detectors, what do they cost, and how much good mail do they block?

The six from the proposal, plus what review added

#	Objective	Delivered	Status
1	Decontaminated benchmark	9 sources, 3 levels of matching, exact verification, matcher validated	Done
2	Leave-one-corpus-out	6 folds, raw, decontaminated, and a random-removal control	Done
3	One protocol, all families	classical, DistilBERT, 6 small LLMs, 3 published detectors, 2 commercial	Done
4	Cost in dollars	measured charge for every one of 40,498 calls	Done
5	AI-written phishing	English, Italian, German, plus sanitised copies	Done
6	One honest table	F1, false alarms, cost, with paired intervals and significance tests	Done
+	Added after review	label study, base-rate analysis, two-stage detectors, explanation quality	Done

Six steps, and one control that decides the argument



The control that makes it evidence

Removing duplicates also removes data. So we run a third setting that removes the **same number** of training emails at random. If that changes nothing, the drop is the duplicates.

Same emails for everyone

A fixed 300-email subset per test set. Local, open and paid models are all scored on exactly those emails.

What exactly we ran

Source	Role	Used	Eval
spamassassin	train+test	5,803	300
ceas08	train+test	10,000	300
trec07	train+test	10,000	300
ling	train+test	2,858	300
enron	train+test	10,000	300
kaggle	train+test	10,000	300
nazario	test only	1,554	150
nigerian	test only	3,316	150
ephishllm	test only	10,000	300
ephishllm_it	test only	2,701	300
ephishllm_de	test only	2,349	300

Classical

TF-IDF 1-2 grams, 50k features, LogReg / Naive Bayes, 0.21 s per 1,000 emails

DistilBERT

1 epoch, 128 tokens, 1,000 emails per corpus, laptop CPU, raw and decontaminated

11 detectors through one protocol

6 small open LLMs (1B to 14B), 3 published phishing models, Gemini-3.1-Flash-Lite and GPT-4o-mini. Temperature 0, 1,500 chars

Reproducible

Seed 42, 8 GB MacBook, every raw answer saved, total API spend \$1.58

The standard check finds almost none of it

SpamAssassin emails that also sit inside the Kaggle set

EXACT TEXT

2

0.03%

NO WHITESPACE

3,850

66.34%

NEAR DUPLICATE

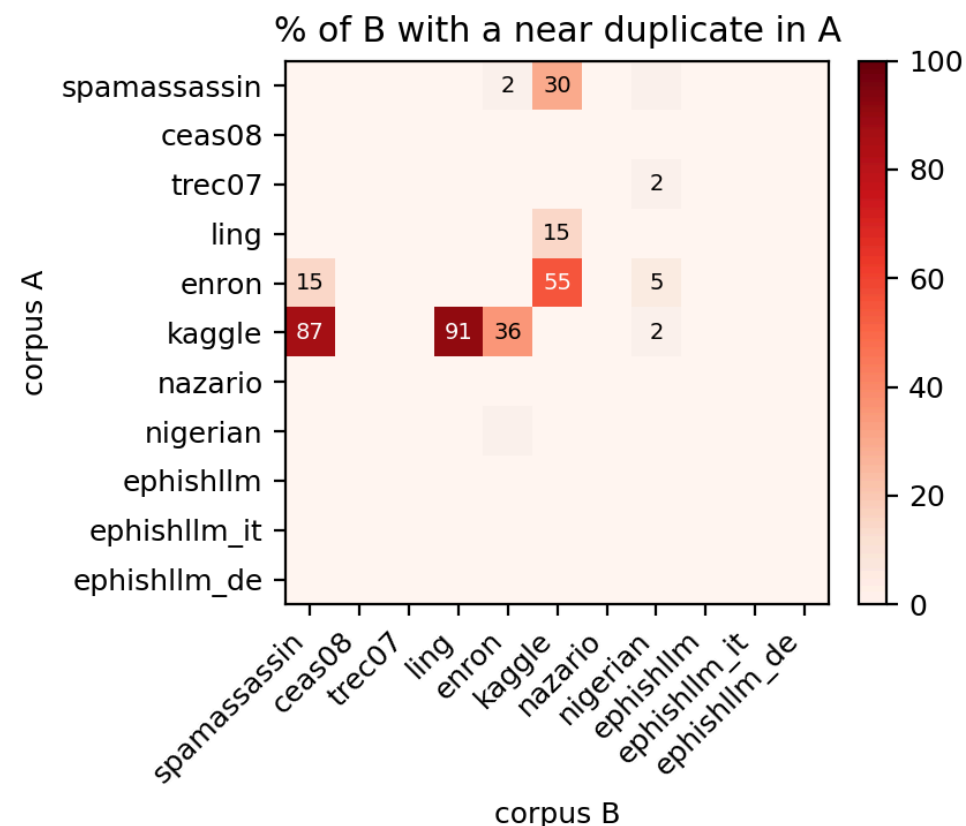
5,032

86.71%

93% of the Kaggle corpus has a near copy in another corpus. At the stricter 0.9 threshold it is still 86%.

Verified. Every pair is confirmed with exact similarity, not an estimate. Against brute force on 400 hard cases the matcher has precision 1.00 and recall 1.00.

Inside a single corpus, 9 to 19% of its own test emails have a near copy in its training part.

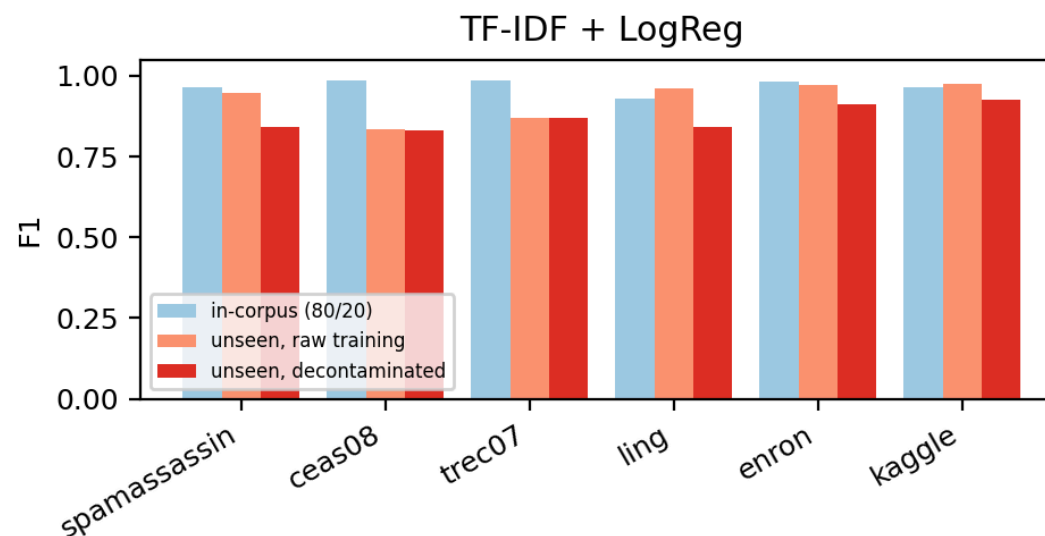


And the control shows it is the duplicates, not the data

Held-out corpus	Raw	Random removal	Decontaminated
spamassassin	0.947	0.947	0.840
ceas08	0.833	0.833	0.832
trec07	0.871	0.871	0.871
ling	0.962	0.960	0.841
enron	0.972	0.970	0.911
kaggle	0.976	0.972	0.927

Remove the same number of emails **at random**: nothing changes.
Remove the **duplicates**: up to 12 points disappear.

Kaggle to SpamAssassin transfer, the suspicious result from July: 0.966 before, 0.672 after. CEAS and TREC, which share nothing, do not move at all.



Most of the phishing in these corpora is not phishing

Corpus	Positives	Phishing	Spam
spamassassin	150	19%	81%
ceas08	150	15%	85%
trec07	150	25%	75%
ling	150	19%	79%
enron	150	21%	79%
kaggle	150	25%	75%

Only 15 to 25% of the "phishing" emails are phishing.

The rest is ordinary bulk advertising. Two annotators, agreement 86%.

So a paper reporting "phishing detection" on these corpora is mostly reporting spam detection. Every model we tested is slightly better on the phishing part than on the spam part.

WHY THIS MATTERS

Nazario is real credential phishing and is the only corpus that is purely phishing. It is also the set where the classical models are weakest.

We keep the published labels, but we now know what they mean, and we report detection separately for the two kinds.

Unseen corpora, false alarms, AI phishing and cost

Model	In-corpus F1	Unseen-corpus F1	False alarms	AI phishing F1	\$ / 1,000
Gemini-3.1-Flash-Lite	–	0.960	2%	0.950	\$0.080
GPT-4o-mini	–	0.950	4%	0.917	\$0.046
Qwen-2.5-7B	–	0.928	3%	0.819	\$0.033
Llama-3.1-8B	–	0.881	21%	0.817	\$0.012
Gemma-3-12B	–	0.882	25%	0.955	\$0.017
Llama-3.2-3B	–	0.850	5%	0.507	\$0.017
Phi-4-14B	–	0.727	28%	0.759	\$0.022
Llama-3.2-1B	–	0.623	60%	0.474	\$0.009
TF-IDF + LogReg	0.968	0.899	10%	0.640	local
DistilBERT	0.975	0.891	6%	0.540	local
BERT-phishing (published)	–	0.962	3%	0.470	local
Phishsense-1B (published)	–	0.947	7%	0.839	local

Trained models use decontaminated data. The published detectors were trained on the same corpora we test on, which is why their unseen-corpus column and their AI-phishing column disagree so strongly.

We checked our own good result, twice

The worry. The AI corpus writes links as the token <<link>>: in 94 of 150 phishing emails, in none of the legitimate ones. If models react to the token, our AI-phishing numbers mean nothing.

Recall on AI phishing	With token	Without	Split gap	Paired gap
Qwen-2.5-7B	0.78	0.55	+0.22	+0.03
Llama-3.1-8B	0.81	0.52	+0.29	+0.02
Gemma-3-12B	1.00	0.96	+0.04	+0.00
TF-IDF + LogReg	0.69	0.54	+0.16	+0.01

Two tests, two answers. Comparing emails that have the token with emails that do not suggests it is worth 16 points. But removing the token from the **same** emails changes recall by 0.9 points.

The first test was confounded: emails with links are simply easier than text-only business-email-compromise lures. The result stands.

THE LESSON

When you suspect a shortcut, change that one thing on the same data.

The quick comparison would have made us report a finding that is not there.

A balanced test set is not a mailbox

Recomputed for a mailbox where 5% of mail is phishing

Model	Recall	False alarms	F1 at 5%	Wrongly flagged per 1,000
Gemini-3.1-Flash-Lite	0.94	2%	0.833	16
Qwen-2.5-7B	0.89	3%	0.725	28
TF-IDF + LogReg	0.90	10%	0.484	91
Gemma-3-12B	0.98	25%	0.289	239

Gemma looked best on AI phishing. In a real inbox it would flag 239 good emails in every 1,000.

CHEAP TWO-STAGE DETECTOR

TF-IDF first, LLM only on what it flags

F1 0.911, false alarms 1.1%, **\$0.0161 per 1,000**, about half the cost of the LLM alone and fewer false alarms than either part.

RECALL-FIRST VERSION

Let Gemma re-check what Qwen cleared: AI-phishing recall 0.99, but 25% false alarms. That is a review queue, not a blocker.

Right answers come with real reasons, wrong ones do not

WHEN THE VERDICT IS CORRECT

91%

of reasons point at something that is really in the email (Qwen; Gemma 92%)

WHEN THE VERDICT IS WRONG

53%

a wrong answer usually comes with an invented reason

Also measured: McNemar tests on the paired predictions. Qwen beats the classical models and DistilBERT on the six unseen corpora ($p < 0.001$). Few-shot examples from old corpora do **not** significantly help there ($p = 0.22$) but significantly hurt on AI-written mail ($p < 0.001$). Swapping in AI-written examples recovers most of that loss, which is the controlled version of the claim.

This matters for deployment: showing a model's explanation to a user is safe only if the verdict is checked first.

Four things we would tell another team

1. Check overlap before claiming generalisation

Five minutes of near-duplicate matching on a laptop. Exact matching finds 2 of 5,032 shared emails.

2. Cheap detectors are usable, in the right order

TF-IDF in front of Qwen-2.5-7B: F1 0.911 at 1.1% false alarms for \$0.0161 per 1,000. A paid model is still better on every axis.

3. Report false alarms and the base rate

At 5% phishing the ranking changes. One F1 number cannot tell you what a detector does to an inbox.

4. Be suspicious of your own good numbers

Our AI-phishing result was partly a placeholder token. We found it by checking, and we report both versions.

High accuracy on one dataset is easy. **Honest evaluation is the hard part.**

What this study does not show

We are not first to test across corpora

E-PhishGen (2025) and Bhuiyan (2026) did. Ours adds decontamination, cost and false alarms.

300 emails per test set

Interval about ± 0.015 , so small differences are not meaningful. We report intervals and significance tests.

Our annotator is a model

Two models, 86% agreement on a shared sample, but not hand-labelled by us.

LLM pre-training is unknown

The old corpora may be inside these models already. The 2025 AI corpus is the cleanest test we have.

Different input budgets

TF-IDF sees 20,000 characters, LLMs 1,500, DistilBERT 128 tokens. DistilBERT's row is a lower bound.

One prompt, one run

No prompt search, and providers can change a model behind the same name.

What we can finish next

DAYS 1 TO 4

Hand-labelled subset

The three of us label 300 positives as phishing or spam, to replace the model annotator on the headline claim.

DAYS 5 TO 8

Threshold calibration

Ask each LLM for a confidence, then set the operating point per corpus, following the recalibration result of Gutierrez et al.

DAYS 9 TO 11

Bigger test sets

1,000 emails per set for the top three models to tighten the intervals. Under \$1 more.

DAYS 12 TO 14

Write-up

Final paper, a short artifact README, and the deduplication script packaged so other groups can run it on their own corpora.

Everything reuses the existing scripts. Budget left: about \$3 of the \$5.

Everything is public and re-runnable

GITHUB

github.com/Jahid15/phishing-llm-cross-corpus

code, every raw model answer, results, paper, research log, team guide

COLAB NOTEBOOK

[notebooks/phishing_llm_cross_corpus.ipynb](https://colab.research.google.com/notebooks/phishing_llm_cross_corpus.ipynb)

loads every result in seconds, or reruns all the steps

TOTAL SPEND

\$1.58

of a \$5 budget

MODEL CALLS

40,498

all answers saved

HARDWARE

1 laptop

8 GB, no GPU rental

Thank you. Questions?